

THIRD-PARTY MANAGEMENT POLICY

Acme Financial Services

Document Owner: Chief Information Security Officer

Policy ID: TPM-001

Version: 1.0

Effective Date: June 2026

Review Frequency: Annual

Classification: Internal Use

Prepared by: Vearnell Israel

DOCUMENT CONTROL

Document Information	Details
Policy Name	Third-Party Management Policy
Policy ID	TPM-001
Version	1.0
Document Owner	Chief Information Security Officer
Classification	Internal Use
Effective Date	June 2026
Review Frequency	Annual
Approval Authority	Executive Leadership Team
Framework Alignment	NIST CSF 2.0, ISO 27001
Next Review Date	June 2027

REVISION HISTORY

Version	Date	Description of Change	Author
1.0	June 2026	Initial Release	Vearnell Israel

1. PURPOSE

The purpose of this Third-Party Management Policy is to establish a consistent and risk-based approach for evaluating, approving, managing, and monitoring third-party relationships that support Acme Financial Services business operations.

Third-party relationships can introduce cybersecurity, operational, financial, legal, privacy, and regulatory risks that may impact the confidentiality, integrity, and availability of company information and systems. As a result, Acme Financial Services requires all third parties that access company information, systems, networks, applications, cloud environments, or customer data to meet defined security and compliance requirements throughout the lifecycle of the relationship.

This policy establishes minimum requirements for vendor due diligence, risk assessments, contract management, security monitoring, incident reporting, and vendor offboarding activities to ensure third-party risks are identified, assessed, and appropriately managed.

2. SCOPE

This policy applies to all Acme Financial Services employees, contractors, consultants, temporary workers, business units, and departments responsible for selecting, managing, or overseeing third-party relationships.

This policy applies to all third-party vendors, suppliers, service providers, consultants, contractors, managed service providers, cloud service providers, software vendors, business partners, and other external organizations that access, process, transmit, store, support, or otherwise interact with company information, systems, applications, or customer data.

Compliance with this policy is mandatory. Any exception must be documented, reviewed by the Information Security team, and approved by the Chief Information Security Officer or authorized executive leadership.

3. THIRD-PARTY MANAGEMENT REQUIREMENTS

3.1 Third-Party Risk Assessment

All prospective third parties shall undergo a documented risk assessment before engagement, contract execution, or access to company information and systems.

Risk assessments shall evaluate the third party's access to sensitive information, access to technology systems, service criticality, business impact, regulatory obligations, privacy considerations, and cybersecurity maturity.

Third parties identified as presenting elevated levels of risk may require additional reviews, remediation activities, or executive approval prior to engagement.

3.2 Vendor Classification

Third parties shall be classified according to the level of risk they present to the organization.

Vendor classifications may include Critical, High, Moderate, or Low Risk categories. Examples of classification criteria include the sensitivity of data processed, level of system access, regulatory obligations, dependency on the vendor for business operations, and potential operational impact if services become unavailable.

Risk classifications shall determine the frequency of assessments, monitoring activities, and security oversight requirements.

3.3 Due Diligence Reviews

Acme Financial Services shall perform appropriate due diligence activities before engaging third parties.

Due diligence activities may include security questionnaires, review of independent audit reports, evaluation of cybersecurity certifications, financial assessments, privacy reviews, regulatory compliance evaluations, penetration test summaries, and review of information security policies.

Due diligence findings shall be documented and retained according to records management requirements.

Third parties determined to present unacceptable levels of risk shall not be approved until identified risks are mitigated or formally accepted by executive leadership.

3.4 Contractual Security Requirements

All third-party agreements shall include security, privacy, confidentiality, and compliance requirements appropriate to the services being provided.

Contracts shall address information protection requirements, data ownership, incident notification obligations, audit rights, regulatory compliance responsibilities, data retention requirements, and requirements for the secure handling of customer information.

Third parties shall agree to maintain security controls that are consistent with contractual, regulatory, and organizational requirements.

3.5 Vendor Inventory Management

Acme Financial Services shall maintain a centralized inventory of approved third-party relationships.

The inventory shall document vendor ownership, services provided, contract status, risk classification, data classifications involved, system access levels, review dates, and other information necessary to support risk management activities.

Business owners shall be responsible for maintaining accurate vendor information throughout the vendor lifecycle.

3.6 Ongoing Monitoring

Third-party relationships shall be monitored throughout the duration of the engagement.

Monitoring activities may include periodic risk assessments, review of independent audit reports, review of security certifications, evaluation of security incidents, assessment of regulatory compliance, and verification that contractual requirements continue to be satisfied.

The frequency and scope of monitoring activities shall be based on vendor risk classification and business criticality.

3.7 Incident Reporting

Third parties shall promptly report any cybersecurity incident, unauthorized access, security breach, operational disruption, privacy event, or compromise involving company information, systems, applications, or customer data.

Third parties shall cooperate with investigations, provide requested information, support remediation efforts, and comply with contractual reporting requirements.

Failure to report a security incident in a timely manner may result in contractual penalties, increased oversight, or termination of the business relationship.

Security incidents affecting company information shall be reported within timeframes established by contractual agreements and applicable regulatory requirements.

3.8 Vendor Offboarding

When a third-party relationship is terminated, the organization shall ensure that access to company systems, applications, networks, and information is removed in a timely manner.

Company information shall be returned, securely destroyed, or retained according to contractual and regulatory requirements.

Vendor records shall be updated to reflect termination of services, and all offboarding activities shall be documented and reviewed to ensure security requirements have been satisfied.

4. POLICY SANCTIONS

Failure to comply with this policy may result in corrective or disciplinary action in accordance with Acme Financial Services policies, contractual agreements, and applicable laws.

Violations may result in suspension of services, termination of vendor relationships, removal of system access, disciplinary action, financial penalties, contract termination, or legal proceedings, depending upon the severity of the violation.

Incidents involving negligence, unauthorized access, misuse of company information, failure to comply with contractual obligations, or violations of regulatory requirements may result in additional enforcement actions.

5. REVIEW AND APPROVAL

This policy shall be reviewed annually by the Information Security, Compliance, Legal, Procurement, and Risk Management teams and approved by executive leadership.

Updates may be made sooner when significant business, regulatory, operational, technology, vendor risk, or cybersecurity changes occur.

This policy becomes effective upon approval by executive leadership and shall remain in effect until superseded or withdrawn.

Approved By:

Chief Information Security Officer

Date: _____

Executive Leadership Team

Date: _____